Gate Before You Act

Does verifying evidence make an LLM security agent act more safely than policy rules alone?

INTERNATIONAL INSTITUTE OF INFORMATION TECHNOLOGY HYDERABAD

PROBLEM AND RESEARCH QUESTION

Security agents now act: they isolate hosts, kill processes and disable accounts. Policy gates check whether an action is *allowed*, not whether the logs *justify* it.

Question: with policy, context, model and tools fixed, does also checking that cited evidence supports the action improve decisions, and which part helps?

Domain: SOC first response on one Windows host.
Baselines: plain agent (G0) and policy-only gate (G1).

H1: full gate admits ≥15 pts fewer bad actions than policy-only.

H1-C4: the LLM verifier alone gives ≥10 pts.

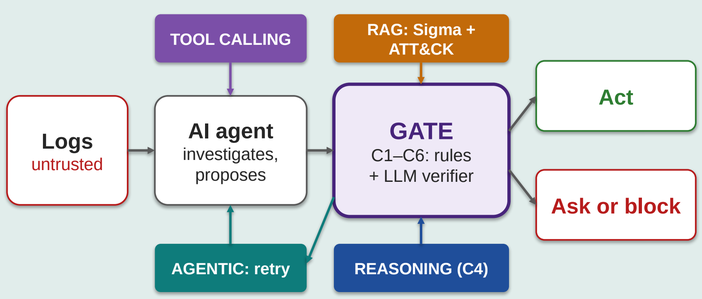
H2: unnecessary deferral at most 10 pts worse.

METHODOLOGY

Data: 99 real Windows attack recordings (757k log events) → 31 test scenarios, 217 cases with known answers. Each correct evidence package gets broken copies: harmless citations, wrong host, partial or contradicted chain, covered by an approved ticket.

Gate: C1 allow-list + provenance, C2 citation scope, C3 target match (code), C4 LLM verifier, C5 policy, C6 approval.

Setup: 10 configurations, each differing in one part; Qwen2.5-7B (4-bit) on one 8 GB laptop GPU; 4 runs, 0 errors.



RESULTS

H1
29.0 pts
[20.1, 38.7] fewer bad actions let through
SUPPORTED

H1-C4
16.1 pts
[6.5, 27.4] of that from the LLM verifier
SUPPORTED

H2
+35.5 pts
[25.7, 45.9] more unnecessary deferral
NOT MET

Reasoning: the LLM verifier gives 16 of the 29 points, but never once said "contradicted" (0 of 2,604 calls).

RAG: no / simple / reranked retrieval: the reranker doubles Hit@5 (0.063 → 0.132), yet decisions do not change.

Agentic: recovery budget 0 / 1 / 2 queries and direct vs MCP tools: outcomes move by at most 2 points.

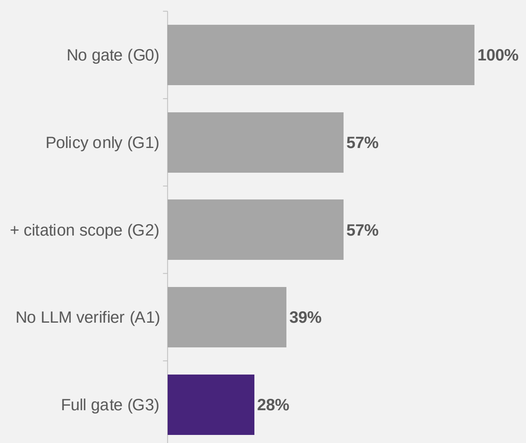
Tool calling: 96% valid tool calls; the gate admits 16% of unsafe calls (policy-only 47%); the planted injection was blocked.

Exp 3 (live investigation): every system found only 2 of 24 attack techniques, which caps what any gate can do.

EXP 1: GATE DECISIONS

Every gate judged the same fixed evidence packages. Policy alone still let **57%** of bad packages through; the full gate **28%**.

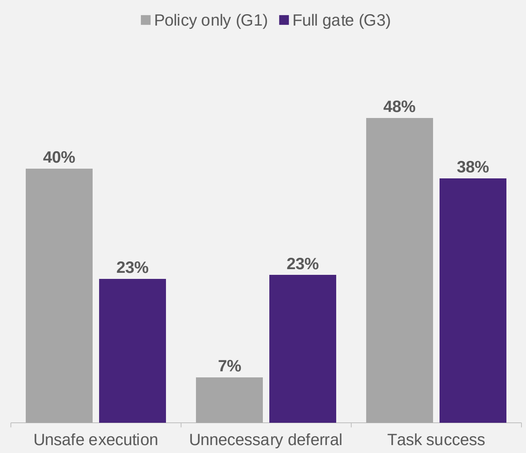
The price: the full gate wrongly blocked **35%** of correct packages; policy-only blocked none.



EXP 2: FULL EPISODES

In full agent episodes the gate nearly halves unsafe executions, but after a wrong "not enough evidence" the agent asks the analyst instead of acting.

On correct packages it defers **40%** of the time (policy-only 5%).



Simpletons

Team | LMA (CL3.410)

CONCLUSION AND FUTURE WORK

- Checking evidence makes the agent **safer** (29 pts fewer bad actions) but **more hesitant** (+35 pts deferral).
- The gate design holds up, including with tools served over MCP.
- Retrieval, recovery and MCP do not fix it: the verifier's calibration is the bottleneck.
- Next: verdict after ticket comparison, filled-in feedback, stronger verifier, human label check.

ACKNOWLEDGMENT

We thank the LMA course team. Data: OTRF Security-Datasets, SigmaHQ rules, MITRE ATT&CK®. Test-case labels were produced by separate AI agent sessions under our written rules.

REFERENCES

[1] J. Barnes. OpenSec: Measuring Incident Response Agent Calibration Under Adversarial Evidence. arXiv:2601.21083, 2026.

[2] E. Debenedetti et al. Defeating Prompt Injections by Design. arXiv:2503.18813, 2025.

[3] H. Wang et al. AgentSpec: Runtime Enforcement for Safe LLM Agents. arXiv:2503.18666, 2025.

[4] S. Yao et al. ReAct. arXiv:2210.03629, 2022.

[5] OTRF Security-Datasets; SigmaHQ; MITRE ATT&CK v19.2.

[6] CERT-In Directions under Sec. 70B(6), 28 April 2022.

Code: github.com/varunmodi18/Gate-Before-You-Act

Author names: Varun Modi (2025202040), Aayush Pandey (2025201058), Srushti Pekamwar (2025201066), Dhruv Rajput (2025201094)